

PLANEA REPRESENTACIONES VIAJES Y EVENTOS S.A.S.

NIT 900.546.983 — Viaja América

## PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD DE DATOS PERSONALES

| Código    | Versión | Fecha de aprobación      | Aprobado por        |
|-----------|---------|--------------------------|---------------------|
| PR-IDP-01 | 1.0     | 25 de septiembre de 2026 | Representante Legal |

### 1. Objetivo

Definir cómo se detectan, reportan, contienen, evalúan, notifican y cierran los incidentes de seguridad que afecten datos personales tratados por la Compañía, en cumplimiento del literal n) del artículo 17 y del literal k) del artículo 18 de la Ley 1581 de 2012, y de las instrucciones de la Superintendencia de Industria y Comercio (Circular Única, Título V) sobre reporte de incidentes a través del RNBD.

### 2. Alcance

Aplica a todos los colaboradores, contratistas y proveedores de la Compañía y a toda la información personal en medios físicos o digitales, incluidos los datos entregados por clientes corporativos en calidad de Encargado.

### 3. Definiciones

- Incidente de seguridad de datos personales:** violación de los códigos de seguridad o pérdida, robo y/o acceso no autorizado a información de una base de datos (p. ej. envío de datos de viajeros al destinatario equivocado, pérdida de un portátil o celular, acceso indebido a correo o plataformas de reserva, ransomware, pérdida de documentos físicos).
- Evento sospechoso:** situación que podría constituir un incidente y debe evaluarse.
- Equipo de respuesta:** Oficial de Protección de Datos (líder), Representante Legal y soporte tecnológico interno o externo.

### 4. Roles

| Rol                                                              | Responsabilidad                                                                                                                                         |
|------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Cualquier colaborador o contratista                              | Reportar de inmediato (máximo 24 horas) cualquier evento sospechoso al Oficial de Protección de Datos.                                                  |
| Oficial de Protección de Datos (Norma Consuelo Linares Buitrago) | Registrar, clasificar y coordinar la respuesta; notificar a la SIC, clientes corporativos y Titulares; documentar el cierre y las lecciones aprendidas. |
| Representante Legal                                              | Aprobar decisiones de alto impacto, recursos y comunicaciones externas.                                                                                 |
| Soporte tecnológico                                              | Contener técnicamente (bloqueo de cuentas, cambio de contraseñas,                                                                                       |

| Rol | Responsabilidad                                                      |
|-----|----------------------------------------------------------------------|
|     | aislamiento de equipos), preservar evidencias y restaurar servicios. |

## 5. Canales de reporte interno

- Correo: **administrativo1@viajaamerica.com.co** con asunto "INCIDENTE DATOS PERSONALES".
- Llamada o WhatsApp al Oficial de Protección de Datos: **+57 318 708 0678**.

El reporte debe incluir: quién reporta, fecha y hora del hallazgo, qué ocurrió, qué información o sistemas están involucrados y acciones ya tomadas.

## 6. Etapas del procedimiento

| # | Etapas                               | Actividades                                                                                                                                                                                                                               | Plazo                                                   |
|---|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| 1 | Detección y reporte                  | El colaborador reporta el evento por los canales definidos. No borra evidencias ni intenta investigar por su cuenta.                                                                                                                      | Inmediato — máx. 24 h desde el conocimiento             |
| 2 | Registro                             | El Oficial registra el caso en el Registro de Incidentes (Anexo A) y le asigna un consecutivo.                                                                                                                                            | Mismo día                                               |
| 3 | Contención                           | Bloqueo de accesos, cambio de credenciales, aislamiento de equipos, solicitud de eliminación a destinatarios erróneos, recuperación de documentos.                                                                                        | Primeras 24–48 h                                        |
| 4 | Evaluación y clasificación           | Determinar tipo de datos, número de Titulares, si hay datos sensibles o de menores, si hay datos de clientes corporativos, causa y nivel de riesgo (bajo, medio, alto).                                                                   | Máx. 72 h                                               |
| 5 | Notificación a clientes corporativos | Si el incidente afecta datos entregados por un cliente (p. ej. Samsung), informarle sin demora indebida, con la descripción del incidente, datos afectados, medidas adoptadas y punto de contacto, o en el plazo contractual si es menor. | Sin demora — máx. 72 h desde la confirmación            |
| 6 | Reporte a la SIC                     | Reportar el incidente a la Superintendencia de Industria y Comercio a través del módulo de incidentes del RNBD (o por el canal que la SIC disponga cuando la Compañía no esté obligada al RNBD).                                          | Dentro de los 15 días hábiles siguientes a su detección |
| 7 | Comunicación a Titulares             | Cuando exista riesgo para los derechos de los Titulares, informarles lo ocurrido y las recomendaciones para mitigar el riesgo.                                                                                                            | Tan pronto sea posible                                  |

| # | Etapas                        | Actividades                                                                                                                                                                   | Plazo                                      |
|---|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|
| 8 | Erradicación y recuperación   | Eliminar la causa raíz, restaurar sistemas o información desde copias de seguridad, verificar la integridad.                                                                  | Según el caso                              |
| 9 | Cierre y lecciones aprendidas | Informe final (causa, impacto, acciones, plan de mejora con responsables y fechas). Revisión del procedimiento si es necesario. Conservación de evidencias por mínimo 5 años. | Máx. 30 días calendario tras la contención |

## 7. Criterios de clasificación del riesgo

| Nivel | Criterio                                                                                                                                                                    |
|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Alto  | Datos sensibles, de menores, documentos de identidad/pasaportes, datos financieros; o más de 100 Titulares; o datos de clientes corporativos; o evidencia de uso malicioso. |
| Medio | Datos de identificación y contacto de un número limitado de Titulares sin evidencia de uso malicioso.                                                                       |
| Bajo  | Exposición mínima, contenida inmediatamente (p. ej. correo erróneo interno eliminado y confirmado).                                                                         |

Todos los incidentes confirmados se reportan a la SIC, independientemente de su nivel; la clasificación define la prioridad y la comunicación a Titulares.

## 8. Prueba del procedimiento

El procedimiento se prueba al menos **una vez al año** mediante un ejercicio de simulación (p. ej. envío erróneo de un listado de viajeros), cuyo resultado se documenta en el informe de auditoría anual (PR-AUD-01).

## Control de cambios

| Versión | Fecha                    | Descripción del cambio         |
|---------|--------------------------|--------------------------------|
| 1.0     | 25 de septiembre de 2026 | Emisión inicial del documento. |

## Anexo A. Formato de Registro de Incidentes

| Campo                                  | Descripción  |
|----------------------------------------|--------------|
| Consecutivo                            | INC-AAAA-NNN |
| Fecha y hora de detección / de reporte |              |

| Campo                                        | Descripción         |
|----------------------------------------------|---------------------|
| Reportado por                                |                     |
| Descripción del incidente                    |                     |
| Bases de datos / sistemas afectados          |                     |
| Tipo de datos y número de Titulares          |                     |
| ¿Datos de clientes corporativos?<br>¿Cuál?   |                     |
| Nivel de riesgo                              | Alto / Medio / Bajo |
| Acciones de contención                       |                     |
| Fecha de notificación al cliente corporativo |                     |
| Fecha y radicado de reporte a la SIC         |                     |
| Comunicación a Titulares (sí/no, fecha)      |                     |
| Causa raíz                                   |                     |
| Plan de mejora (acción, responsable, fecha)  |                     |
| Fecha de cierre y firma del Oficial          |                     |

## Aprobación



**Carlos Enrique Bonilla Sánchez**

C.C. 80.231.516

Representante Legal — PLANEIA REPRESENTACIONES VIAJES Y EVENTOS S.A.S.



**Norma Consuelo Linares Buitrago**

Directora de Seguridad de la Información (CISO) — Oficial de Protección de Datos Personales